

AegisCare HMS / LabTrack v5.5

Data	FACILITY_NAME, FACILITY_ADDRESS (KMHFL code: FACILITY_KMHFL_CODE)
controller	
System	AegisCare HMS / LabTrack v5.5 (https://aegiscarehms.lovable.app ; facility deployment: FACILITY_DEPLOYMENT_URL)
Applicable laws	Kenya Data Protection Act, 2019 (No. 24 of 2019); Digital Health Act, 2023; Social Health Insurance Act, 2023; Public Health Act, 2017; HIV/AIDS Prevention and Control Act, 2006; Children Act, 2022; Digital Health (Data Exchange Component) Regulations, 2025
Status	DRAFT for review; to be published to patients and submitted with the DHA certification pack
Date	2026-08-12

This policy is both a patient-facing notice (plain-language sections marked "For patients") and the regulatory-facing privacy statement for FACILITY_NAME. Where a placeholder appears (FACILITY_*, ODPC_REG_NO, DPO_NAME), the developer must substitute confirmed values before publication.

Section 1 — Data Controller Information

- Controller: FACILITY_NAME, FACILITY_ADDRESS, telephone FACILITY_PHONE, email FACILITY_EMAIL.
- KMHFL code: FACILITY_KMHFL_CODE; SHA facility/provider ID: FACILITY_SHA_ID / FACILITY_SHA_PROVIDER_NO (configured in the system's app_settings single global row).
- Registration with ODPC: ☐ PENDING — FACILITY_NAME will register as a data controller with the Office of the Data Protection Commissioner (<https://www.odpc.go.ke>) before go-live; ODPC registration number to be inserted here: ODPC_REG_NO.
- Data Protection Officer: DPO_NAME, DPO_EMAIL, DPO_PHONE. ☐ PENDING until appointed.
- Data processor: Lovable (managed hosting) and Supabase (database, auth, edge functions, project tgynjasgnerucrlwedui), both processing under contractual terms and platform security defaults (AES-256 at rest, TLS 1.2+ in transit). Facility staff are users of the system, not data controllers.

Section 2 — Data We Collect

The system stores the following categories of personal and special-category (sensitive) data. Column references are to the live database schema ([supabase/migrations/](#)).

Category	Examples (actual columns)	Sensitive
Identity & demographics	patients.first_name, middle_name, family_name, date_of_birth, sex, national_id, national_id_type, photo_url, blood_group, allergies	Personal

Category	Examples (actual columns)	Sensitivity
National identifiers	patients.national_id (National ID / Passport / Birth Certificate / Alien ID); patients.cr_number (DHA Client Registry ID)	Special (identity)
SHA	patients.sha_member_number, sha_relationship_to_principal, sha_membership_status, sha_membership_verified_at; encounters.sha_notification_number, preauth_number, claim_number	Special
Contact	patients.phone, email, address_line1/2, city, county, postal_code, country	Personal
Clinical record	encounters.vitals, history, diagnoses (JSONB); encounter_diagnoses (ICD-11); clinical_notes.content; lab_orders/lab_results.result; radiology_results.findings; prescriptions.drug_name, dosage; medication_administrations	Special (health)
Visit & billing	encounters.payment_mode, tests, subtotal, insurance_covered; invoices; invoice_line_items; invoice_payments; insurance_providers	Personal financial
Admission & care	admissions, beds, wards, encounter_room_visits, mortuary_records (deceased data), appointments	Special
Consent evidence	consent_otps (SHA-256 hash of OTP, phone, type, timestamps — plaintext OTP never stored); patient_consents (types given/refused, hie_data_sharing_consented, timestamps, staff user)	Special
Staff & access	profiles (username, names, council_* registration), user_roles, role_permissions, user_room_access, audit_log (who changed what), shr_transmission_log	Personal
System	app_settings, moh_* aggregates (de-identified counts), stock_items, stock_movements, deliveries, machines	Non-personal

For patients: We record your name, national ID, contact details, and your medical information — diagnoses, tests, results, prescriptions, admissions and billing — in your electronic record at FACILITY_NAME. We also record your consent choices for treatment and data sharing.

Section 3 — Legal Basis for Processing

Processing activity	Legal basis
Provision of healthcare (registration, diagnosis, treatment, pharmacy, laboratory, admission)	Performance of a contract for health services and vital/healthcare necessity (Kenya DPA 2019 s.30(1)(b),(f)); treatment consent captured in patient_consents (general_treatment) with OTP verification per SHA Act 2023 s.48
SHA claims, preauthorisation, notification numbers	Statutory obligation & public interest — Social Health Insurance Act, 2023; Digital Health Act, 2023; consent evidenced by the s.48 OTP flow (consent_type = 'sha_claim' / 'preauth' in consent_otps)
HIE (AfyaLink) data sharing	Explicit consent — patient_consents.hie_data_sharing_consented = true (optional consent item in ConsentDialog); withdrawal honoured by blocking future syncs
MOH reporting	Statutory obligation — Ministry of Health reporting requirements; data is aggregated (moh_monthly_aggregates) and de-identified
(705/706/707/717/505/642/FP/MCH/204) Audit logging, security, fraud prevention	Legitimate interest of the controller (DPA 2019 s.30(1)(a)); Digital Health (Data Exchange Component) Regulations 2025
Staff credential verification (HWR/KMPDC/NCK)	Legitimate interest and professional-regulation obligation

We do not process data for automated decision-making affecting the patient, and we do not sell or rent personal data.

Section 4 — How We Use Data

4.1 Delivering care: registration, queueing/routing (encounter_room_visits), triage, consultation with ICD-11 coding, laboratory and radiology workflows, pharmacy dispensing (prescriptions, stock_movements), inpatient care (admissions, medication_administrations), mortuary administration.

4.2 Billing and insurance: invoicing (invoices, invoice_line_items, invoice_payments), coverage calculation (insurance-calc.ts rules: percentage / fixed_per_visit / percentage_with_cap), SHA fund classification (set_sha_fund_type() → PHF/SHIF/ECCIF), benefit-package selection (sha_benefit_packages), claims (sha_claims and related), preauthorisation capture and enforcement.

4.3 National reporting: automatic MOH indicator tagging (tag_encounter_demographics(), process_encounter_indicators()) into encounter_indicator_tags → moh_monthly_aggregates, driving forms 204, 505, 642, 705, 706, 707, 717, FP and MCH.

4.4 Statutory record-keeping: append-only audit_log (20 tables, 60 triggers), break-glass records, shr_transmission_log.

4.5 Quality and safety: critical lab result flags (lab_results.is_critical), dual verification (verified_by/verified_at), discharge-summary gate (require_discharge_summary()), encounter signing/locking (enforce_encounter_lock()).

Section 5 — Data Sharing

Recipient	What is shared	Authority / basis	Status
DHA HIE (AfyaLink)	FHIR R4 Patient, Encounter, Condition, MedicationDispense (and future Observation) via dha_outbound_queue → POST /shr/bundles	Explicit consent (hie_data_sharing_consented); Digital Health Act 2023; Data Exchange Governance Regulations 2025	PENDING credentials; consent gate live
SHA	Member number, notification number, diagnoses (ICD-11), benefit packages, claim line items, preauth references	SHA Act 2023 s.48 OTP consent; claims contract	PENDING credentials; local pipeline live
IPRS / Client Registry	National ID (+ type) for identity verification; returns official demographics and CR ID	DPA 2019 lawful basis; patient consent via OTP before lookup	PENDING credentials
Kenya HWR	Practitioner council registration numbers (staff data, not patient data)	Professional regulation	PENDING credentials
WHO (ICD-11 API)	Free-text diagnosis search queries (no patient identifiers)	WHO API terms	PENDING ICD_CLIENT_ID/ICD_CLIENT_SECRET
MOH / KHIS	Aggregated, de-identified indicator counts	Statutory reporting	internal generation
NLMIS / KEMSA	Commodity-level stock data (non-personal)	Supply-chain mandate	integration not yet built
Atika #39;s (SMS)	Phone number + OTP message text (Track B)	s.48 consent messaging	PENDING credentials; Track A (on-screen) live

Recipient	What is shared	Authority / basis	Status
Third parties	None — no data sales, no advertising, no cross-facility sharing	—	—

generally

Deployment model note: each facility runs an isolated deployment (own repository fork, own Supabase project) — no facility can access another facility's data (docs/facility-onboarding.md).

Section 6 — Data Retention

6.1 Clinical records: retained for the duration required by Kenyan law and professional guidance for medical records at a health facility (FACILITY_CLINICAL_RETENTION_YEARS — to be confirmed by the facility's legal adviser; typically the full statutory period for medical records). Deletion of clinical records is not automatic and is subject to legal holds.

6.2 Audit trail: audit_log keeps a hot copy for 2 years; archive_old_audit_logs() then moves older rows to the append-only audit_log_archive (nightly cron archive-audit-logs-nightly, 0 23 * * * UTC), retained for the DHA-required 20-year audit retention period. audit_archive_runs records every archive run for verifiability.

6.3 Consent evidence: consent_otps (10-minute OTP validity; hashes and evidence rows retained with the clinical record) and patient_consent (retained with the record; consent decisions are not auto-expunged).

6.4 Aggregates: moh_monthly_aggregates retained per MOH reporting requirements (historical periods are recomputed on demand via refresh_moh_aggregates()).

6.5 On facility closure or contract end: the facility's data export and destruction procedure applies (see DOC-4 §5); the controller will notify data subjects and the ODPC as applicable.

Section 7 — Patient Rights

Under the Kenya Data Protection Act, 2019 (s.26), patients may exercise:

Right	How it is honoured in AegisCare
Access	Request a copy of your record; the facility exports it from the system (DOC-4 §5 export path).
Correction	Corrections made by authorised staff; every correction is recorded in audit_log with before/after values; signed (status='signed') encounters are locked by enforce_encounter_lock() and corrected through encounter_amendments to preserve the clinical record's integrity.
Deletion	GAP/LIMITATION: full deletion of clinical records is limited by law (medical record retention obligations, audit immutability, claims evidence). Erasure applies to data not required for care/legal purposes; the facility will assess each request.
Objection	Honoured where no statutory basis applies; where processing is required by law (SHA claims, MOH reporting) the objection is recorded in patient_consent and noted.
processing	HIE sharing can be withdrawn at any time — the consent gate (hie_data_sharing_consented) blocks future FHIR Withdrawalsyncs immediately (checked in claims-dispatcher FhirSyncHandler); already-transmitted records are handled per consent DHA procedures.

Right	How it is honoured in AegisCare
Data portability	Structured export (FHIR R4 resources are available via fhir-patient, fhir-encounter, fhir-condition; database dump via DOC-4 §5).
Lodge with the facility (Section 10) and/or ODPC.	
Complaint	

Requests should be made to the DPO (Section 1) or the facility records office (records_officer role). Response time: 14 days (extendable per DPA).

Section 8 — Security Measures

Personal and health data are protected by the controls described in full in DOC-6 — Security Policy. Summary:

- Access control: 19-role RBAC (is_approved(), role_permissions, user_room_access), Row-Level Security on all clinical tables, admin-only user provisioning, 30-minute inactivity logout.
- Integrity: append-only audit log (20 tables), encounter signing/locking, amendment trail, SHR transmission log.
- Confidentiality: TLS 1.2+ in transit; AES-256 at rest (Supabase platform); secrets in Supabase only; OTPs stored as SHA-256 hashes.
- Consent enforcement: FHIR/HIE sync is gated on recorded consent; the client is notified when their SHR record is accessed (trg_shr_access_notification).
- Oversight: break-glass access requires justification and is audited.

Section 9 — Consent

9.1 Treatment & data privacy consent (general_treatment, data_sharing) — mandatory for a visit; captured through the OTP flow in ConsentDialog (src/components/consent-dialog.tsx):

- A 6-digit code is generated, stored only as a SHA-256 hash in consent_otps with a 10-minute expiry;
- the receptionist shares the code with the patient (Track A, on-screen) — ☐ PENDING SMS delivery (Track B, Africa's Talking, s.48-compliant SMS text);
- verification marks the OTP verified and writes the consent rows to patient_consents with the staff user, timestamp, and items given/refused;
- a printed slip is offered (slip data: OTP reference, time, given/refused).

9.2 SHA claims consent — the SHA Act 2023 s.48 statutory text is embedded in the flow: `"By sharing this code, you consent to treatment and SHA claims processing under Sec 48 of the Social Health Insurance Act 2023. False statements carry statutory penalties."`

9.3 HIE data sharing — optional consent item (hie_data_sharing); when declined, no FHIR sync is queued (verified in claims-dispatcher).

9.4 Special consents — surgical, HIV testing, anaesthesia are captured as explicit optional items; HIV-related data is additionally protected under the HIV/AIDS Prevention and Control Act, 2006 (confidentiality obligations).

9.5 Minors & dependants — consent is collected from the parent/guardian (sha_relationship_to_principal supports dependent relationships); the DHA SHR dependant-consent flow (representative_cr_id) will be used once live.

Section 10 — Contact & Complaints

- Facility: FACILITY_NAME, FACILITY_ADDRESS, FACILITY_PHONE, FACILITY_EMAIL.
- Data Protection Officer: DPO_NAME, DPO_EMAIL (☐ PENDING appointment).
- System developer: AegisCare Development Team (repository `fmurage6331-dev/confit-core`).
- Regulator: Office of the Data Protection Commissioner, 2nd Floor, BRITAM Tower, Hospital Road, Upper Hill, Nairobi; complaints@odpc.go.ke; <https://www.odpc.go.ke>. ODPC registration of the facility: ODPC_REG_NO (☐ PENDING).
- Health-sector regulators: DHA (info@dha.go.ke), SHA (<https://provider.sha.go.ke>), county health management team.

Complaints handling: acknowledge within 7 days; resolve within 30 days; escalate to ODPC where unresolved.

Review & Version History

Version	Date	Change	Author
1.0 draft	2026-08-12	Initial draft for certification pack	AegisCare Development Team

Review cycle: annually, or on any material change to data processing, sharing, or retention.

End of DOC-3.